

SYS.1.10 Server unter OpenBSD

1 Beschreibung

1.1 Einleitung

OpenBSD ist ein freies, Unix-ähnliches Betriebssystem. Es zeichnet sich durch einen proaktiven Sicherheitsansatz, umfassende Code-Audits und die tiefe Integration kryptografischer sowie architekturenspezifischer Sicherheitsfunktionen aus. Das Entwicklungsziel ist die Bereitstellung eines hochsicheren Mehrzweck-Betriebssystems nach dem Prinzip "Secure by default".

Durch dedizierte Sicherheitsmechanismen (wie Address Space Layout Randomization, W[^]X, pledge und unveil) wird OpenBSD häufig für sicherheitskritische IT-Systeme und Netzkomponenten eingesetzt, beispielsweise als Firewall, VPN-Gateway oder Plattform für Intrusion-Detection-Systeme. Die Architektur, die mitgelieferten Werkzeuge und das Release-Modell erfordern für den sicheren Betrieb jedoch spezifische Kenntnisse.

1.2 Zielsetzung

Ziel des Bausteins ist es, die spezifischen Gefährdungen beim Betrieb von Servern unter OpenBSD aufzuzeigen und Anforderungen für eine sichere Konfiguration, Administration und Wartung zu definieren. Dabei sollen die in das System integrierten Sicherheitsfunktionen systematisch genutzt werden, um eine widerstandsfähige Server-Plattform bereitzustellen.

1.3 Abgrenzung und Modellierung

Der Baustein SYS.1.10 ist auf alle IT-Systeme anzuwenden, auf denen das Betriebssystem OpenBSD betrieben wird.

Er konkretisiert und ergänzt die Anforderungen aus SYS.1.1 *Allgemeiner Server*. Der Baustein SYS.1.1 wird durch diesen Baustein nicht ersetzt, sondern muss zusätzlich umgesetzt werden. Wird der OpenBSD-Server primär als netzwerkseparierende Komponente eingesetzt, sind ergänzend die Anforderungen des Bausteins NET.3.2 *Firewall* zu berücksichtigen. Allgemeine Aspekte des Systembetriebs sind im Baustein OPS.1.1.2 *Ordnungsgemäßer IT-Betrieb* geregelt.

2 Gefährdungslage

Für Server unter OpenBSD sind folgende spezifische Gefährdungen von besonderer Bedeutung:

Umgehung der Sicherheitsmechanismen durch fehlerhafte Konfiguration

OpenBSD ist in der Grundinstallation sicherheitsbewusst konfiguriert ("Secure by default").

Werden durch Administratoren unsachgemäße Anpassungen vorgenommen, können die eingebauten Schutzmechanismen ausgehebelt werden. Dies umfasst beispielsweise übermäßig freizügige Firewall-Regeln, das Deaktivieren von Speicherschutzfunktionen für Drittanbieter-Software oder das fehlerhafte Erstellen eigener Skripte ohne Nutzung von Limitierungsmechanismen.

Veraltete Systemversionen durch inkonsequentes Patchmanagement

Das OpenBSD-Projekt veröffentlicht halbjährlich eine neue Version und stellt für die aktuelle sowie die vorherige Version Sicherheitspatches bereit. Werden diese Patches nicht zeitnah eingespielt oder die halbjährlichen Release-Upgrades versäumt, verbleibt das System auf einem nicht mehr unterstützten Stand und ist gegen neu entdeckte Schwachstellen ungeschützt.

Unsichere Einbindung von Drittanbieter-Software

Während das Basissystem einem kontinuierlichen und intensiven Sicherheits-Audit unterliegt, gilt dies nicht im selben Maße für die Pakete und Portierungen von Drittanbietern. Die Installation unnötiger oder fehlerhaft konfigurierter Zusatzsoftware kann die Gesamtsicherheit des Systems erheblich mindern und Angriffsvektoren eröffnen.

Kompromittierung durch unsachgemäße Administration

Trotz der robusten technischen Absicherung auf Betriebssystemebene können administrative Fehler das System gefährden. Die Verwendung des root-Kontos für alltägliche administrative Arbeiten ohne Nachvollziehbarkeit, die Erlaubnis passwortbasierter Remote-Logins oder eine unzureichende Protokollierung sicherheitsrelevanter Ereignisse erleichtern Angreifern die Kompromittierung des Systems.

3 Anforderungen

Im Folgenden sind die spezifischen Anforderungen des Bausteins SYS.1.10 aufgeführt. Grundsätzlich ist der IT-Betrieb für die Erfüllung der Anforderungen zuständig. Abweichungen werden in den entsprechenden Anforderungen gesondert genannt.

Zuständigkeiten	Rollen
Grundsätzlich zuständig	IT-Betrieb
Weitere Zuständigkeiten	Entwickler, Informationssicherheitsbeauftragter (ISB)

3.1 Basis-Anforderungen

Die folgenden Anforderungen MÜSSEN vorrangig erfüllt werden.

SYS.1.10.A1 Planung des Servereinsatzes unter OpenBSD (B)

Vor der Installation MUSS eine Planung erfolgen, für welche konkreten Aufgaben der OpenBSD-Server eingesetzt werden soll. Es MUSS festgelegt werden, welche Dienste und Drittanbieter-Software für den Betrieb zwingend erforderlich sind.

SYS.1.10.A2 Gesicherte und minimalistische Installation (B)

Die Installation des Betriebssystems MUSS von einem kryptografisch verifizierten Installationsmedium (z. B. via signify) erfolgen. Während der Installation DÜRFEN ausschließlich die für den Einsatzzweck zwingend benötigten Dateisets ausgewählt werden. Für das lokale Administrator-Konto (root) MUSS ein sicheres Passwort vergeben werden.

SYS.1.10.A3 Regelmäßiges Einspielen von Sicherheitspatches (B)

Es MUSS ein Prozess etabliert werden, der sicherstellt, dass bereitgestellte Sicherheitspatches für das OpenBSD-Basisssystem zeitnah und systematisch (z. B. unter Nutzung des Werkzeugs syspatch) eingespielt werden.

SYS.1.10.A4 Aktivierung und Basiskonfiguration der Firewall (B)

Die systemeigene Paketfilter-Firewall MUSS aktiviert werden. In der zugehörigen Regelbasis MUSS eine "Default Deny"-Strategie umgesetzt sein, bei der jeglicher Netzwerkverkehr standardmäßig blockiert und nur explizit benötigter Datenverkehr erlaubt wird.

SYS.1.10.A5 Absicherung des administrativen Fernzugriffs (B)

Der Secure-Shell-Dienst (SSH) MUSS so konfiguriert werden, dass eine direkte Anmeldung des root-Benutzers unterbunden ist. Die passwortbasierte Authentifizierung MUSS serverseitig deaktiviert sein; stattdessen MUSS für den administrativen Fernzugriff ein schlüsselbasiertes kryptografisches Verfahren erzwungen werden.

SYS.1.10.A6 Kontrollierte Installation von Drittanbieter-Software (B)

Software, die nicht Teil des auditierten OpenBSD-Basisystems ist, DARF ausschließlich über die offiziellen Paketquellen (Packages/Ports) aus vertrauenswürdigen Repositories installiert werden. Es DARF nur Software installiert werden, die für den definierten Einsatzzweck des Servers zwingend erforderlich ist.

3.2 Standard-Anforderungen

Gemeinsam mit den Basis-Anforderungen entsprechen die folgenden Anforderungen dem Stand der Technik bei normalem Schutzbedarf. Sie SOLLTEN grundsätzlich erfüllt werden.

SYS.1.10.A7 Systematische Release-Upgrades (S)

Es SOLLTE ein Prozess etabliert werden, um die halbjährlichen Release-Upgrades des OpenBSD-Projekts zeitnah durchzuführen (z. B. unter Nutzung des automatisierten sysupgrade-Mechanismus). Es SOLLTE sichergestellt werden, dass ausschließlich Versionen betrieben werden, für die das Projekt noch offiziellen Support und Sicherheitsaktualisierungen anbietet.

SYS.1.10.A8 Konsequente Deaktivierung nicht benötigter Dienste (S)

Alle im Basissystem enthaltenen, aber für den spezifischen Einsatzzweck des Servers nicht benötigten Hintergrunddienste und Daemons SOLLTEN dauerhaft deaktiviert werden.

SYS.1.10.A9 Härtung der Dateisysteme (S)

Für die eingebundenen Dateisysteme SOLLTEN restriktive und sicherheitsrelevante Mount-Optionen konfiguriert werden. Insbesondere SOLLTEN Partitionen, auf denen keine Gerätedateien, Setuid-Binaries oder ausführbaren Programme erwartet werden (z. B. /tmp, /var oder /home), mit den Optionen nodev, nosuid und noexec eingebunden werden, sofern dies technisch umsetzbar ist.

SYS.1.10.A10 Konfiguration der Systemprotokollierung (S)

Der Systemprotokollierungsdienst SOLLTE so konfiguriert werden, dass sicherheitsrelevante Ereignisse, Authentifizierungsversuche und Firewall-Logs umfassend erfasst werden. Die Protokolldaten SOLLTEN über eine verschlüsselte Verbindung an ein zentrales Log-Management- oder SIEM-System weitergeleitet werden.

3.3 Anforderungen bei erhöhtem Schutzbedarf

Die folgenden Anforderungen sind exemplarisch und bei erhöhtem Schutzbedarf zu berücksichtigen; die konkrete Festlegung erfolgt im Rahmen einer Risikoanalyse. Der Schutzziel-Bezug ist am Ende jeder Anforderung in Klammern angegeben (C = Vertraulichkeit, I = Integrität, A = Verfügbarkeit).

SYS.1.10.A11 Einsatz von Festplattenverschlüsselung (H)

Das gesamte System oder Datenträger mit sensiblen Informationen SOLLTEN mit der in das Betriebssystem integrierten Verschlüsselung (z. B. softraid) verschlüsselt werden. (C, I)

SYS.1.10.A12 Hochverfügbarkeit für sicherheitskritische Netzwerkkomponenten (H)

Wird OpenBSD als sicherheitskritische Netzwerkkomponente eingesetzt, SOLLTE ein hochverfügbarer Cluster (z. B. mittels CARP und pfsync) aufgebaut werden, um eine redundante und ausfallsichere Funktion sicherzustellen. (A)

SYS.1.10.A13 Nutzung erweiterter Sicherheitsmechanismen für eigene

Anwendungen (H) [Entwickler]

Werden auf dem System eigene Anwendungen oder komplexe Skripte entwickelt und betrieben, SOLLTEN diese so konzipiert oder angepasst werden, dass sie die systemeigenen Sicherheitsmechanismen zur Einschränkung von Systemaufrufen (z. B. pledge) und zur Limitierung des sichtbaren Dateisystems (z. B. unveil) nutzen. (C, I, A)

SYS.1.10.A14 Erstellung eines gehärteten, angepassten Kernels (H)

Für Systeme mit maximalen Schutzanforderungen SOLLTE ein eigener Kernel kompiliert werden. Dabei SOLLTEN alle nicht zwingend benötigten Treiber, Protokolle und Funktionalitäten entfernt werden, um die potenzielle Angriffsfläche weiter zu minimieren. (I, A)

SYS.1.10.A15 Regelmäßige Überprüfung der Systemintegrität (H)

Die Integrität der Dateien des Basissystems SOLLTE regelmäßig überwacht werden, indem die kryptografischen Prüfsummen der installierten Dateien gegen die offiziellen Signaturen des jeweiligen Releases abgeglichen werden. (I)

4 Weiterführende Informationen

4.1 Wissenswertes

Das OpenBSD-Projekt stellt eine umfassende und stets aktuelle Dokumentation in Form von Manpages zur Verfügung, die als primäre Referenz für die Konfiguration herangezogen werden sollten. Ergänzend bietet die offizielle OpenBSD-FAQ tiefgehende Anleitungen zu den Besonderheiten der Installation, dem Paketmanagement und der Konfiguration grundlegender Dienste.

Für die Konfiguration der Firewall ist die Spezifikation zur pf.conf einschlägig. Für tiefgreifende Informationen zu Sicherheitsmechanismen und dem Systemaufbau wird auf die Handbücher des Projekts sowie auf Publikationen im Bereich der Unix-Systemsicherheit verwiesen.

Kreuzreferenztable zu elementaren Gefährdungen

Die folgenden elementaren Gefährdungen sind für den Baustein SYS.1.10 von Bedeutung:

- G 0.18 Fehlplanung oder fehlende Anpassung
- G 0.19 Offenlegung schützenswerter Informationen
- G 0.20 Informationen oder Produkte aus unzuverlässiger Quelle
- G 0.21 Manipulation von Hard- oder Software
- G 0.22 Manipulation von Informationen
- G 0.23 Unbefugtes Eindringen in IT-Systeme
- G 0.25 Ausfall von Geräten oder Systemen
- G 0.28 Software-Schwachstellen oder -Fehler
- G 0.30 Unberechtigte Nutzung oder Administration von Geräten und Systemen

- G 0.31 Fehlerhafte Nutzung oder Administration von Geräten und Systemen
- G 0.39 Schadprogramme
- G 0.40 Verhinderung von Diensten (Denial of Service)

Anforderung	G 0.18	G 0.19	G 0.20	G 0.21	G 0.22	G 0.23	G 0.25	G 0.28	G 0.30	G 0.31	G 0.39	G 0.40
SY S.1 .10 .A1 (B)	X											
SY S.1 .10 .A2 (B)			X	X						X		
SY S.1 .10 .A3 (B)								X			X	
SY S.1 .10 .A4 (B)						X						X
SY S.1 .10 .A5 (B)		X				X			X			
SY S.1 .10			X					X			X	

.A6 (B)												
SY S.1 .10 .A7 (S)								X			X	
SY S.1 .10 .A8 (S)	X					X				X		
SY S.1 .10 .A9 (S)				X							X	
SY S.1 .10 .A1 0 (S)	X									X		
SY S.1 .10 .A1 1 (H)		X			X							
SY S.1 .10 .A1 2 (H)							X					X
SY				X				X			X	

S.1 .10 .A1 3 (H)												
SY S.1 .10 .A1 4 (H)						X		X				
SY S.1 .10 .A1 5 (H)				X	X						X	